CNOVI PROGRAMACIÓN WAP

Reporte laboratorio #12: File path taversal Validation of file extension with null byte bypass



Lizeth Infante Martínez

Reporte de Laboratorio: File path taversal Validation of file extension with null byte bypass

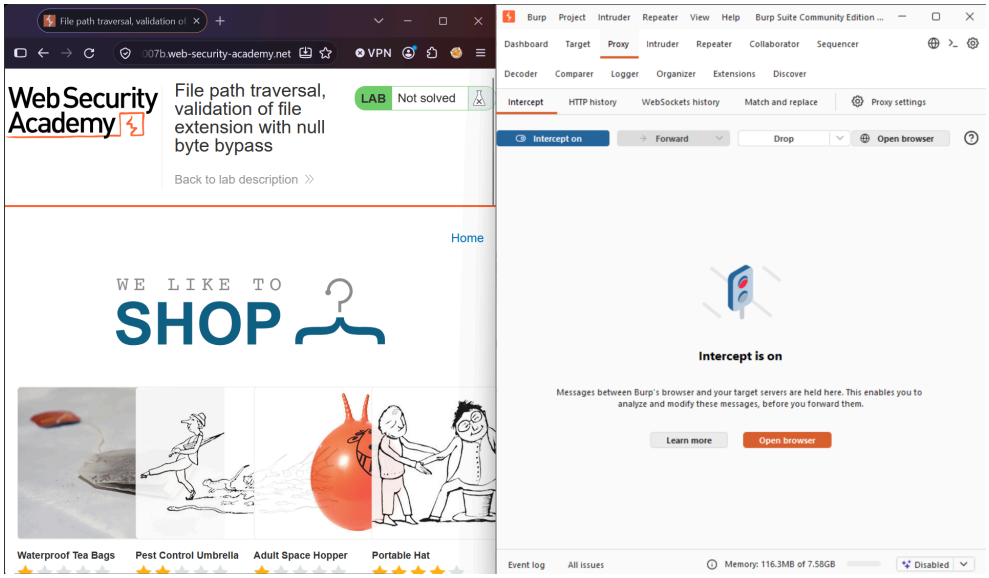
1. Objetivo

Demostrar la vulnerabilidad de salto de directorio cuando la aplicación valida que el nombre de archivo suministrado termine con una extensión esperada (como .png), aplicando una técnica de omisión de byte nulo (null byte bypass). Se utiliza Burp Suite para interceptar, modificar el parámetro filename añadiendo secuencias de salto (../../../etc/passwd) seguidas de un byte nulo codificado (%00) y la extensión requerida (.png) para lograr que el backend procese el archivo objetivo omitiendo los caracteres posteriores.

2. Metodología y Pasos de Resolución

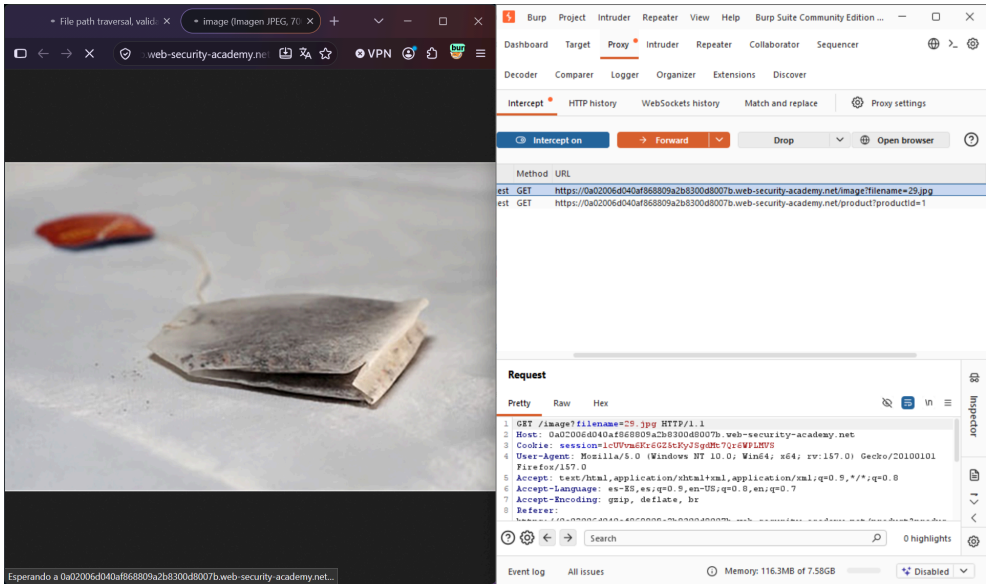
Paso 1: Configurar la intercepción en Burp Suite

- Ve a la pestaña Proxy en Burp Suite y asegúrate de que el botón indique Intercept on (Interceptación activada).



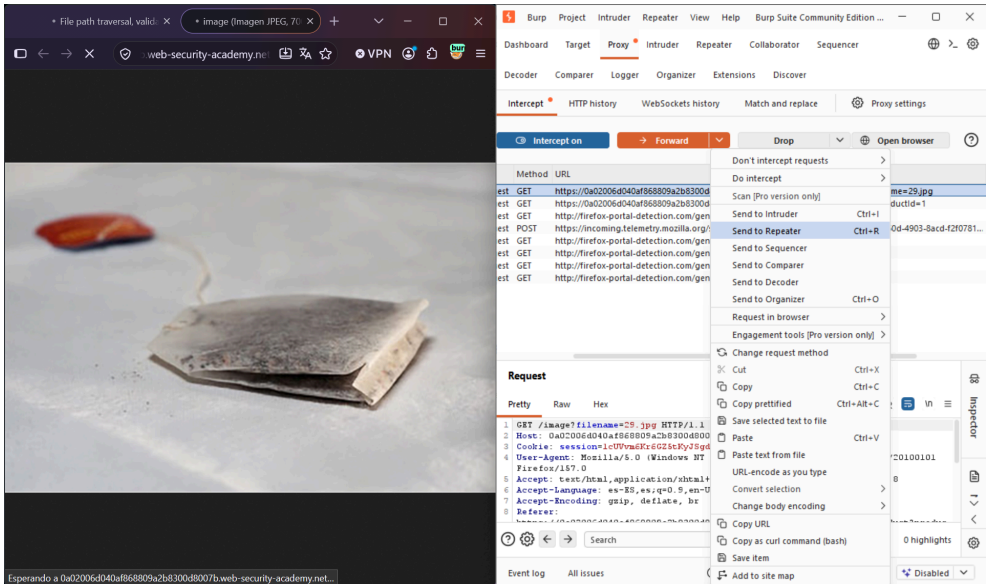
Paso 2: Generar la petición de una imagen de producto

- Dirígete a la ventana del navegador integrada en Burp o a tu navegador configurado con el proxy.
- Haz clic en cualquiera de los productos de la tienda para ver los detalles o cargar una imagen y generar la solicitud HTTP correspondiente.



Paso 3: Interceptar, modificar la solicitud y usar el Repeater

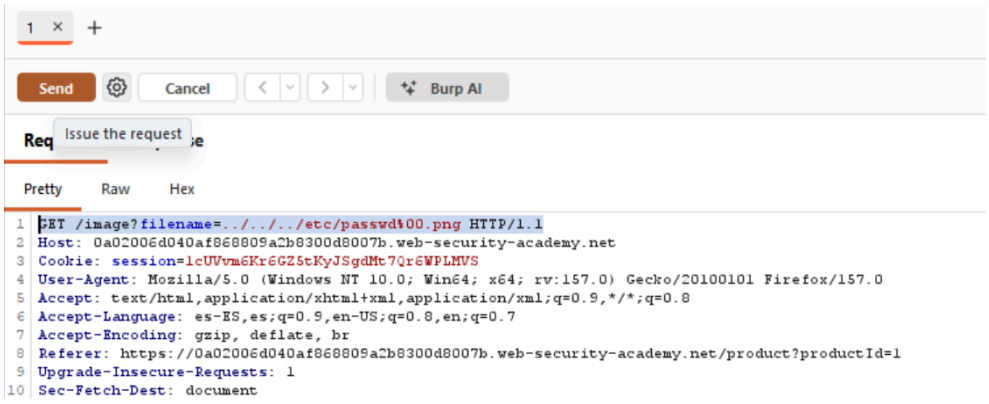
- La petición se pausará en Burp Suite en la pestaña Proxy > Intercept.
- En la lista de HTTP history, localiza la petición correspondiente para cargar la imagen y haz clic derecho para seleccionar Send to Repeater .



- Abre la pestaña Repeater en el menú superior de Burp Suite.
- En el panel de la petición HTTP, ubica la primera línea y modifica el parámetro filename utilizando las secuencias de salto de directorio seguidas del archivo objetivo, el byte nulo codificado (%00) y la extensión permitida para superar la validación del sistema:

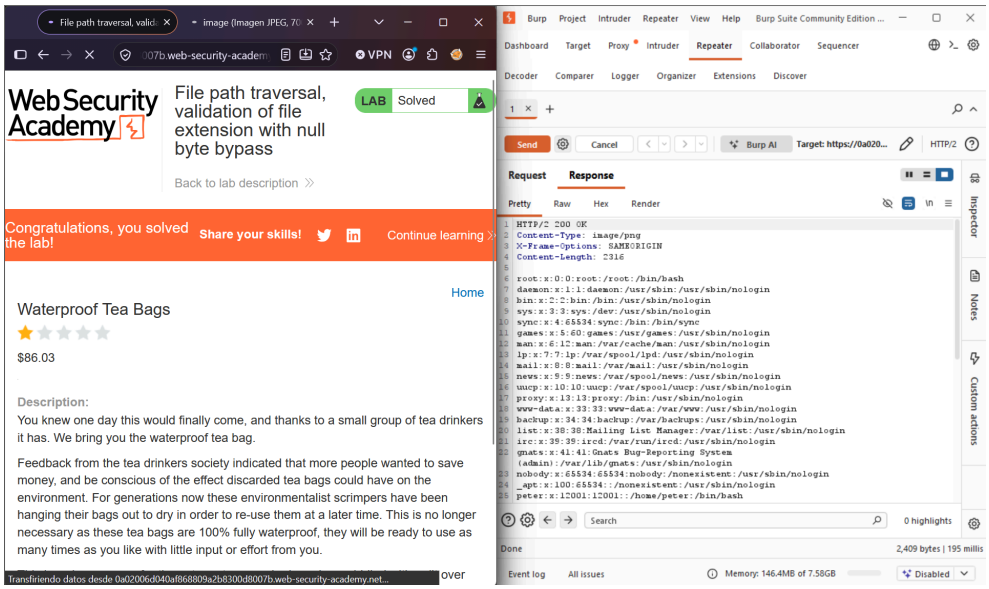
GET /image?filename=../../../etc/passwd%00.png HTTP/1.1

- Haz clic en el botón Send en la esquina superior izquierda de la pestaña Repeater para emitir la solicitud.



3. Verificación y Resultados

- **Panel de Respuesta (Repeater):** Al enviar la petición modificada, revisa el panel de respuesta (Response). Se observa el código de estado 200 OK y el contenido completo del archivo /etc/passwd (líneas de texto que comienzan con usuarios como root:x:0:0..., daemon:x:1:1..., etc.), lo que confirma que el bypass por byte nulo y la explotación fueron exitosos.
- **Navegador:** Al comprobar el estado en el navegador del laboratorio, se visualiza la notificación de que el reto ha sido completado satisfactoriamente (Congratulations, you solved the lab!).




Back to all topics
What is path traversal?
Reading arbitrary files via path traversal
Common obstacles
Preventing
View all path traversal labs
Lab: File path traversal, validation of file extension with null byte bypass
APPRENTICE
LAB
Solved
This lab contains a path traversal vulnerability in the display of product images.
The application validates that the supplied filename ends with the expected file extension.
To solve the lab, retrieve the contents of the /etc/passwd file.
ACCESS THE LAB
Solution